

This tool can be configured on Linux/Mac (Windows support is still under discussion).

What data does IoT Inspector collect? For each IoT device in the network, IoT Inspector collects the following information and sends it to identified secure servers at the Princeton University:

- Device manufacturers, based on the first six characters of the MAC address of each device on the network
- DNS requests and responses
- Destination IP addresses and ports contacted — but not the public-facing IP address (i.e., the one that your ISP assigns to you)
- Scrambled MAC addresses (i.e., those with a salted hash)
- Aggregate traffic statistics, i.e., the number of bytes sent and received over a period of time
- The names of devices on the identified network

By collecting the above types of data, there are some risks involved, such as:

- Performance degradation
- Data breaches
- Best-effort support

How the security validation is done: Princeton releases its findings in a journal/conference publication. When consumers are unsure about whether to buy a new IoT device or not, they can read the relevant papers before making a decision, checking if the device of interest features in the Princeton data. Otherwise, the consumer can always buy the product, analyse it with IoT Inspector, and return it if the results are unsatisfactory.

Open Web Application Security Project (OWASP) set of standards

OWASP is an open community dedicated to enabling organisations to conceive, develop, acquire, operate and maintain applications that can be trusted.

Testing an IoT device for poor authentication/authorisation

(OWASP I2): When we think of weak authentication, we might think of passwords that are not changed on a regular basis, six-to-eight character passwords that are nonetheless easy to guess, or of systems without multi-factor authentication mechanisms. Unfortunately, with many smart devices, weak authentication causes major havoc.

Many of the IoT devices are secured with default passwords like '1234', 'password', or 'ABCD'. Users put their password checks in client-side Java code, send credentials without using HTTPS or other encrypted transport protocols, or require no passwords at all. This kind of mismanagement of passwords causes a lot of damage to devices.

Many OWASP I2 to I10 standards provide different levels of security, which are listed in Figure 3.

- I1 – Insecure Web interface
- I2 – Insufficient authentication/authorisation
- I3 – Insecure network services
- I4 – Lack of transport encryption
- I5 – Privacy concerns
- I6 – Insecure cloud interface
- I7 – Insecure mobile interface
- I8 – Insufficient security configurability
- I9 – Insecure software/firmware
- I10 – Poor physical security

Mainflux platform: For authentication and authorisation

Mainflux is an open source IoT platform providing features like edge computing and consulting services. Mainflux Labs is a technology

company offering an end-to-end, open source patent-free IoT platform, an LF EdgeX Foundry compliant IoT edge gateway with an interoperable ecosystem of plug-and-play components, and consulting services for the software and hardware layers of the IoT technology. It provides enhanced and fine-grained security via the deployment-ready Mainflux authentication and authorisation server, with an access control scheme based on customisable API keys and scoped JWT. It also offers mutual TLS (mTLS) authentication using X.509 certificates, NGINX reverse proxy for security, load balancing and termination of TLS and DTLS connections, etc. Many of these features can be explored and used according to the need of the hour.

Best practices for building a secure IoT framework

To prevent/avoid attacks on any IoT device, environment or ecosystem, the following best practices need to be applied:

- Always use strong passwords for device accounts and Wi-Fi networks.
- It is a best practice to always change default passwords.
- Use stronger and most recent encryption methods when setting up Wi-Fi networks such as WPA2.
- Develop the habit of disabling or protecting the remote access to IoT devices when not needed.
- Use wired connections instead of wireless, where possible.

OWASP IoT Top Ten	Maturity of List Item	Builds on Existing Knowledge of	
		Application Security	Network Security
I1 - Insecure Web Interface	Mature	Yes	Some
I2 - Insufficient Authentication/Authorization	Mature	Yes	Yes
I3 - Insecure Network Services	Mature	Some	Yes
I4 - Lack of Transport Encryption	Mature	Yes	Yes
I5 - Privacy Concerns	Emerging	Some	Some
I6 - Insecure Cloud Interface	Mature	Yes	Some
I7 - Insecure Mobile Interface	Emerging	No	Yes
I8 - Insufficient Security Configurability	Mature	Yes	Yes
I9 - Insecure Software/Firmware	Mature	Some	Some
I10 - Poor Physical Security	Emerging	No	Some

Figure 3: OWASP IoT